Research Report

Portfolio task 1(a)

Unit code: COS40005
Unit Name: Computing Technology Project A
Submission date: Oct 9

Student Name: Nguyen Duy Hoang
Student ID: 105551448
Semester: September - November 2026

Detection-as-Code: Engineering, Testing, and Validating Cybersecurity Detections

Research Report

Nguyen Duy Hoang
Student ID: 105551448
COS40005 Computing Technology Project A
Swinburne University of Technology

I. Introduction

Enterprises depend on the detection rules in their SIEM platforms to identify malicious activity. However, these rules are often written and tested manually, so some detections fail silently, generate false positives, or leave adversary techniques unmonitored. This report supports a capstone project investigating a Detection-as-Code model. As the only cybersecurity member in a team of five, I focus on one question: how should a detection rule be validated before it is trusted?

II. Research on the Business Domain

A. Security Operations and Threat Detection

Security Operations Centres (SOCs) collect telemetry from endpoints, servers and network devices into a Security Information and Event Management (SIEM) platform, where detection rules raise alerts for analysts to investigate. The quality of these rules determines what a SOC can see, which has led to detection engineering as a specialised discipline. A rule that matches a fixed value, such as a file name or a hash, is easy to evade, because the attacker only needs to change that value. Rules that describe behaviour are harder to evade, but they are more likely to match legitimate activity.

B. The "as-Code" Approach

Software teams use version control, peer review and CI/CD to automate testing and deployment [1]. Detection-as-Code applies the same approach to detection rules. The software engineers in my team build the pipeline, while this report focuses on what the pipeline should test.

C. Challenges

Although detection rules are critical for a SOC, they are often managed informally. Firstly, rule changes often go live without control. Fortuna [2] describes analysts editing a rule in the SIEM console with no diff, no test and no way to roll back. Secondly, writing a good rule requires specific knowledge. Cinque et al. [3] point out that a SIEM only provides the framework for correlation rules, while their content depends on analysts who must know in advance what to look for. Thirdly, many rules create too many false positives. Alahmadi et al. [4] interviewed 21 SOC practitioners and found that most false positives are "benign triggers": the rule matches correctly, but the activity is legitimate in that organisation. Their sample is small and mostly European, so the result may not apply everywhere. However, it supports testing every rule against benign data from the target environment. Finally, Webster [5] notes that many SOCs do not test their rules on an ongoing basis, so they may believe their coverage is better than it really is. In my view, these problems share one cause: detection rules are not tested and measured before they are trusted.

D. Existing Solutions

Table I compares the main existing solutions by how they test detection rules.

The table shows a clear pattern. Firstly, all five solutions mainly answer one question: does the rule fire on a known attack sample? None of them deliberately tests whether the rule still works when the attacker performs the same technique in a different way. Secondly, false positives are either not measured or measured on generic data, which cannot show how noisy a rule will be in a specific organisation [4]. Thirdly, most solutions report ATT&CK coverage from rule tags, not from test results.

SIEMulate [5] is the closest work to this project. It runs Atomic Red Team tests in a CI/CD pipeline and checks if Splunk rules detect them, with an average pipeline time of 26 seconds. However, only 180 of 410 tests could be executed, because the others failed prerequisite checks in the lab. More importantly, only 3 of the 33 evaluated techniques (9.1%) produced at least one detection, although rules were mapped to all of them, so coverage based on tags was very misleading. The author also states that the dataset has no benign activity, so the study cannot make any claim about false positives.

E. Gap Analysis

The review shows one main gap. There is no open method that measures, at the same time, how robust a rule is against variants of the same technique and how many false positives it creates on benign data from the target environment. Because of this gap, coverage reports can claim that a technique is covered when the rule detects only one form of it [5], and false positives are found only after analysts receive them [4]. This project tries to fill this gap with a validation method that tests every rule with attack variants and a benign baseline, measures two metrics, and reports coverage in three levels instead of "covered" or "not covered".

TABLE I
COMPARISON OF HOW EXISTING SOLUTIONS TEST DETECTION RULES

Solution	Tested with attack data	Tested against evasion variants	False positives measured on benign data	ATT&CK coverage based on
SigmaHQ [6]	Yes, regression samples for some rules	No	Partly, a generic set of benign Windows logs, not the target environment	Rule tags
Elastic detection-rules [7]	Partly, emulation scripts are in a separate project	No	No	Rule tags
Splunk security_content [8]	Yes, separate attack data repository	No	No, known false positives are written as text only	Rule tags
Panther [9]	Sample log events in unit tests	No	Partly, hand-written negative examples	Rule tags
SIEMulate [5]	Yes, live Atomic Red Team tests	Partly, several Atomic tests per technique, but not designed for evasion	No, the dataset has no benign data	Test results

III. RESEARCH ON END USERS

The end users of this project are the security people who write, operate and rely on detection rules. This section describes five groups and what each needs from the validation method.

A. Detection Engineers

Detection engineers write and update the rules. Cinque et al. [3] note that rule quality depends on the knowledge of its author, so engineers need objective feedback instead of only their own judgement. Before deployment, they need to know which attack variants a rule misses and how many false positives it creates.

B. SOC Analysts

SOC analysts operate and investigate the alerts. Alahmadi et al. [4] found that analysts are often not satisfied with their tools: many alerts are benign triggers, the tools work like a "black box", and context is missing. Tier 1 analysts need fewer false positives and clear alerts, while tier 2 analysts need context such as the parent process and full command line. Therefore, every rule must include a description, an ATT&CK mapping and its known false positives.

C. Threat Hunters

Threat hunters search for attacks that rules missed. A rule that is too noisy for alerting can still be a useful hunting query, and the coverage levels show hunters which techniques are only weakly covered.

D. Red and Purple Teams

Red and purple teams simulate attacks to test defences, which Ajmal et al. [10] argue is more effective than traditional vulnerability testing. They provide the attack variants, and the results show them which variants are still undetected.

TABLE II
END USERS AND RELATED PROJECT FEATURES

User	Main need	Feature in this project
Detection engineer	Know which variants are missed	Variant detection rate per rule
SOC analyst	Fewer false positives, clear alerts	False-positive rate on benign baseline, required metadata
Threat hunter	Find weakly covered techniques	"Mapped" and "tested" levels
Red/purple team	Feedback on simulated attacks	Results per attack variant
SOC manager/ auditor	Honest view of coverage	Three-level ATT&CK coverage report

E. SOC Managers and Auditors

SOC managers and auditors make decisions from reports, such as which risks are not covered. Al-Sada et al. [11] reviewed more than 50 studies and show that MITRE ATT&CK is widely used to assess defences. However, SIEMulate [5] shows that coverage based on tags can be misleading, so this group receives a report that shows each technique as mapped, tested or robust.

F. Different Needs between User Groups

The groups do not always want the same thing. Detection engineers and red teams want rules that catch as many variants as possible, which makes rules wider. SOC analysts want fewer false positives, which makes rules narrower. In my view, the two metrics make this trade-off visible, so it is decided with data instead of opinion. Table II summarises these needs.

IV. RESEARCH ON THE SOLUTION DOMAIN

The validation method needs four parts: a detection approach, telemetry, test data and metrics. This section compares the options for each part and explains the proposed choice.

A. Detection Approach

Signature rules match fixed values such as hashes or file names. They are precise, but changing one value evades them. Anomaly detection with machine learning can find unknown behaviour, but Arp et al. [12] reviewed 30 security papers and found that many evaluations suffer from pitfalls such as the base rate fallacy and lab-only evaluation, so the reported accuracy can hide a large number of false positives in real use. Analysts also describe such tools as a "black box" that is difficult to trust [4]. Behaviour rules describe what the attacker does, for example an Office program starting PowerShell. They are harder to evade but can match legitimate administration. Behaviour rules are proposed, because the gap is about robustness, and their false positives can be measured.

The rules will be written in Sigma [6], a YAML format that is easy to review and can be converted to many SIEMs. However, Fortuna [2] notes that a converted rule may be valid but match nothing if the field names are wrong, so rules must be tested after conversion, not only checked for syntax.

B. SIEM and Telemetry

Gonzalez-Granadillo et al. [13] found that most commercial SIEMs are very expensive, while open-source options have fewer features but are still usable. Wazuh is proposed because it is free and fits a small lab, although its limited Sigma support requires a conversion step.

Rules can only detect what is logged, so Sysmon is proposed as the main log source. The most useful events are process creation (Event ID 1), network connection (3), process access (10), file creation (11) and registry changes (13). Process creation events include the `OriginalFileName` field, which does not change when an attacker renames a program. Mavroeidis and Jøsang [14] built a threat assessment system on Sysmon logs, which shows that they are detailed enough for detection work.

C. Attack Data and Variants

MITRE Caldera runs full attack chains but needs a server and agents. Atomic Red Team offers small tests, each linked to one ATT&CK technique, which fits testing one rule at a time. Okuma et al. [15] used Atomic Red Team data to map Sysmon logs to ATT&CK techniques and matched 34 of 36 command lines from real attacks. For each technique, the Atomic tests are extended with variants, such as an obfuscated command line, a renamed program or a different parent process.

Webster [5] ran attacks inside the pipeline, but only 180 of 410 tests could be executed because of the environment. In my view, live attacks on every change are too fragile. Therefore, attacks are run once in an isolated lab to record logs, and the pipeline replays these logs whenever a rule changes.

D. Benign Baseline

Because benign triggers depend on the environment [4], the benign baseline is recorded on the lab endpoint during a fixed period of normal activity, such as using Office and a browser, running administration scripts and installing updates. Its limitation is that a lab is simpler than a real organisation, so the measured false-positive rate is only an estimate until it is replaced with approved client data.

E. Metrics and Coverage Levels

The variant detection rate is the number of variants detected divided by the number run. The false-positive rate is the share of all alerts that come from the benign baseline, with the client's target of 5–10%. Because this value depends on how much benign data is replayed, its definition will be confirmed with the client. Each technique then has one of three levels: *mapped* (tagged but not tested), *tested* (at least one variant detected) and *robust* (at least 80% of variants detected and the false-positive target met). With five variants, 80% allows one miss. The ATT&CK Navigator report is coloured by these levels.

F. Example: PowerShell Encoded Commands

For T1059.001, a simple rule alerts when the command line contains `-EncodedCommand`. It passes the basic Atomic test, so it is *tested*. However, PowerShell accepts shortened parameters such as `-enc`, `-ec` and `-e`, and a renamed copy of `powershell.exe` is missed if the rule checks the file name. A behaviour rule uses `OriginalFileName`, accepts the short parameters followed by a long Base64 string, and raises priority when the parent is an Office program. The Base64 check matters, because matching only `-e` would also match `-ExecutionPolicy`. On the benign baseline, administration scripts that use encoded commands may still trigger it, and these are removed with filters on known parent processes. Only then is the technique *robust*. The project will measure these results in the lab.

G. Proposed Workflow

Fig. 1 shows the workflow, and Table III summarises the choices. Every rule change goes through the CI/CD pipeline built by the software engineers in the team, where the rule is converted and tested, and it is deployed to Wazuh only if it passes.

V. KOST Analysis

This section compares the knowledge, skills and technologies required by the method in Section IV with what I have as a final-year student. Table IV shows the comparison, the gap and my plan for each area.

My main strength is in the security field. Throughout the years in university, I worked on centralised logging and monitoring, so I understand how logs move from an endpoint to a SIEM. I am also studying for a penetration testing certificate, which helps me create realistic attack variants.

My biggest gaps are Sigma rule writing and detection metrics. As the only security member, I must reach a working level in Sigma quickly, because the team depends on me for rule content, so it is my priority in the first four weeks.

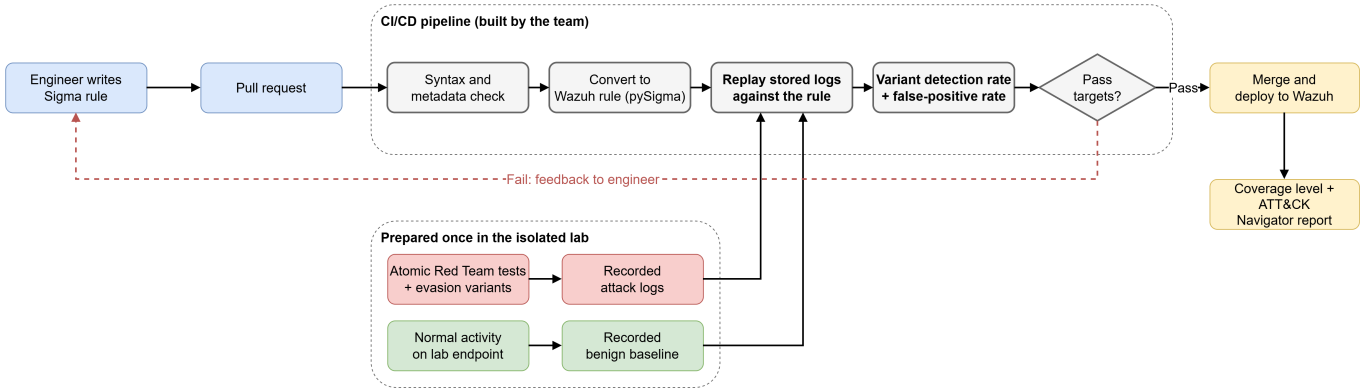


Fig. 1. Proposed detection validation workflow.

TABLE III
SUMMARY OF PROPOSED CHOICES

Component	Options considered	Proposed	Main reason
Detection approach	Signature, behaviour, anomaly (ML)	Behaviour rules in Sigma	Harder to evade, explainable
SIEM	Wazuh, Elastic, Splunk	Wazuh	Open source, fits a small lab
Telemetry	Default Windows logs, Sysmon	Sysmon	Detailed process events
Attack data	Atomic Red Team, Caldera, public datasets	Atomic Red Team + variants	Small tests mapped to ATT&CK
Benign data	None, generic logs, lab baseline	Lab baseline	Closer to the target environment
Test method	Live attacks, log replay	Log replay	Stable and repeatable

VI. Ethical Considerations

This project uses attack simulation and security logs, so it creates three ethical risks. First, attack tools could cause harm if they run outside of the lab. Second, logs can contain personal information such as usernames, hostnames and IP addresses. Third, a wrong detection rule can harm an organisation, either by missing an attack or by creating false alarms. Table V lists the relevant laws and standards and how the project will follow them.

The most important measure is isolation. All attacks run in virtual machines on a host-only network with internet access turned off, and each machine is restored from a clean snapshot after every test, as the project brief requires.

There is also a dual-use issue: rules and attack logs could help an attacker avoid detection. This risk is higher in this project, because the variant set is a list of ways to evade each rule, and the results show which variants are not detected. In my view, sharing tested rules is still useful, because most techniques are already public on MITRE ATT&CK, but the variant set and test results should stay private. Finally, passing the tests is not a guarantee, so the documentation must explain what each rule cannot detect.

VII. Recommendations and Future Directions

Based on the research in the previous sections, I make three recommendations and suggest two directions for future work.

A. Recommendations

Make false positives a measured gate. Because most false positives are benign triggers [4], the client's target of 5–10% should be a pass or fail condition. Following Fortuna [2], a new rule should also run in a silent mode for a short time before it creates real alerts.

Start with a small set of techniques. It is better to cover ten common Windows techniques well than fifty without good tests. Based on commonly reported techniques [16], the first set could be T1059.001, T1003.001, T1547.001, T1053.005, T1218.011, T1036.003, T1105, T1569.002, T1027 and T1112.

Report coverage honestly. The report should show the three levels, not only tags, so that the client does not overestimate its coverage.

B. Future Directions

AI-generated variants. Shukla et al. [17] used a language model to find redundant SIEM rules, with high recall but precision of only about 65–75%, so AI is useful for suggestions but should not decide alone. AI could suggest new variants, while tests and a human reviewer decide.

Cloud telemetry. Several cloud and email techniques are among the most common attacks [16], and the method could be extended to cloud logs because it does not depend on the log source.

References

[1] P. Rostami Mazrae, T. Mens, M. Golzadeh, and A. Decan, "On the usage, co-usage and migration of CI/CD tools: A qualitative analysis," *Empir. Softw. Eng.*, vol. 28, no. 2, Art. no. 52, Mar. 2023, doi: 10.1007/s10664-022-10285-5.

[2] A. Fortuna, "Building a CI/CD pipeline for Sigma rules," Andrea Fortuna. Accessed: Oct. 2, 2026. [Online]. Available: https://andreafortuna.org/2026/06/22/sigma-cicd-pipeline/

TABLE IV
KOST MAPPING

Area	Type	Required for the project	Current level	Gap	Plan
MITRE ATT&CK	Knowledge	Map rules to techniques, read coverage	Beginner	Have not used ATT&CK Navigator	Complete Navigator tutorial in week 4
Windows logging and Sysmon	Knowledge	Know which event shows which behaviour	Beginner	Limited practice with Sysmon event IDs and configuration	Run 10 Atomic tests and study the logs
Detection metrics	Knowledge	Measure detection and false-positive rates	Beginner	Have not measured rule quality before	Agree the definitions with the client, test them on one rule
Sigma rule writing	Skill	Write, tune and filter rules	Beginner	Modifiers, filters, pySigma	Read 5 SigmaHQ rules a day, write 3 rules by week 4 to 5
Attack simulation	Skill	Run Atomic Red Team safely	Medium	Have only run a few techniques	Run the tests for the first 10 techniques
Evasion and obfuscation	Skill	Create realistic attack variants	Medium	Have not used them to test detections	Create 5 variants for each of the first 3 techniques
Python scripting	Skill	Read and adjust validation scripts	Medium	Writing tests	Pair with a developer on one script
Wazuh	Technology	Install, add custom rules	Medium	Custom rule format	Follow official documentation in the lab
VMware and virtual networks	Technology	Build an isolated lab	Good	Automation of lab setup	Document every setup step

TABLE V
RELEVANT PROTOCOLS AND COMPLIANCE MEASURES

Protocol / Act	Why it is relevant	How the project complies
Privacy Act 1988 (Cth) and the Australian Privacy Principles, especially APP 6 and APP 11	Logs may contain personal information	Use only lab data. No real user or client logs are stored in the repository
Criminal Code Act 1995 (Cth), Part 10.7 (computer offences)	Unauthorised access or impairment is a crime	Attack tests run only on virtual machines owned by the team
Security of Critical Infrastructure Act 2018 (Cth)	Detection systems are often used by critical infrastructure operators	Considered as context for future use. No critical systems are tested
ACS Code of Professional Ethics	Sets professional duties such as honesty and public interest	Honest reporting of test results and limitations
Vietnam Law on Personal Data Protection (No. 91/2025/QH15)	The team works in Vietnam	Same data rules as above: no real personal data is collected
Vietnam Law on Cybersecurity (No. 116/2025/QH15)	Regulates activities in cyberspace in Vietnam	All testing stays inside an isolated network with no internet access
Australia's AI Ethics Principles	The team plans an optional AI feature	AI may only suggest rules or variants. Tests and a human reviewer make the final decision

[3] M. Cinque, D. Cotroneo, and A. Pecchia, "Challenges and directions in security information and event management (SIEM)," in *Proc. IEEE Int. Symp. Softw. Rel. Eng. Workshops (ISSREW)*, Memphis, TN, USA, Oct. 2018, pp. 95–99, doi: 10.1109/ISSREW.2018.00-24.

[4] B. A. Alahmadi, L. Axon, and I. Martinovic, "99% false positives: A qualitative study of SOC analysts' perspectives on security alarms," in *Proc. 31st USENIX Security Symp.*, Boston, MA, USA, Aug. 2022, pp. 2783–2800.

[5] R. Webster, "SIEMulate: Automating cybersecurity attack simulations for SIEM validation," D.Eng. praxis, School Eng. Appl. Sci., The George Washington Univ., Washington, DC, USA, 2025. [Online]. Available: ProQuest Dissertations & Theses Global.

[6] SigmaHQ, "Sigma: Main Sigma rule repository," GitHub. Accessed: Oct. 4, 2026. [Online]. Available: https://github.com/SigmaHQ/sigma

[7] Elastic, "detection-rules," GitHub. Accessed: Oct. 4, 2026. [Online]. Available: https://github.com/elastic/detection-rules

[8] Splunk, "security_content," GitHub. Accessed: Oct. 4, 2026. [Online]. Available: https://github.com/splunk/security_content

[9] Panther Labs, "panther-analysis," GitHub. Accessed: Oct. 4, 2026. [Online]. Available: https://github.com/panther-labs/panther-analysis

[10] A. B. Ajmal, S. Khan, M. Alam, A. Mehbodniya, J. Webber, and A. Waheed, "Toward effective evaluation of cyber defense: Threat based adversary emulation approach," *IEEE Access*, vol. 11, pp. 70443–70458, 2023, doi: 10.1109/ACCESS.2023.3272629.

[11] B. Al-Sada, A. Sadighian, and G. Oligeri, "MITRE ATT&CK: State of the art and way forward," *ACM Comput. Surv.*, vol. 57, no. 1, pp. 1–37, Jan. 2025, doi: 10.1145/3687300.

[12] D. Arp, E. Quiring, F. Pendlebury, A. Warnecke, F. Pierazzi, C. Wressnegger, L. Cavallaro, and K. Rieck, "Dos and don'ts of machine learning in computer security," in *Proc. 31st USENIX Security Symp.*, Boston, MA, USA, Aug. 2022, pp. 3971–3988.

[13] G. González-Granadillo, S. González-Zarzosa, and R. Diaz, "Security information and event management (SIEM): Analysis, trends, and usage in critical infrastructures," *Sensors*, vol. 21, no. 14, Art. no. 4759, Jul.

2021, doi: 10.3390/s21144759.
[14] V. Mavroeidis and A. Jøsang, "Data-driven threat hunting using Sysmon," in *Proc. 2nd Int. Conf. Cryptography, Security and Privacy (ICCSP)*, Guiyang, China, Mar. 2018, pp. 82–88, doi: 10.1145/3199478.3199490.
[15] M. Okuma, K. Watarai, S. Okada, and T. Mitsunaga, "Automated mapping method for Sysmon logs to ATT&CK techniques by leveraging Atomic Red Team," in *Proc. 6th Int. Conf. Signal Process. Inf. Security (ICSPIS)*, Dubai, United Arab Emirates, Nov. 2023, pp. 104–109, doi: 10.1109/ICSPIS60075.2023.10343783.
[16] Red Canary, "Top ATT&CK techniques: Threat Detection Report." Accessed: Oct. 5, 2026. [Online]. Available: https://redcanary.com/threat-detection-report/techniques/
[17] A. Shukla, P. A. Gandhi, Y. Elovici, and A. Shabtai, "RuleGenie: SIEM detection rule set optimization," 2025, *arXiv:2505.06701*.